

OIDC field cheat sheet

From first redirect to failed callback: the compact model, checks, and inspection order.

01 What each part is

OAuth 2.0 delegates API access. **OpenID Connect** adds sign-in identity. The **authorization server** issues results; the **resource server** protects the API.

PERSON Approves sign-in or access.	USER AGENT Browser carrying redirects.
CLIENT App requesting identity or API access.	AUTHORIZATION ENDPOINT Front channel: /authorize
CALLBACK Client redirect URI receiving code + state.	TOKEN ENDPOINT Back channel: code → tokens.
ACCESS TOKEN For the resource API; audience is the API.	ID TOKEN For the client; claims describe the sign-in.
REFRESH TOKEN For the client to obtain fresh tokens; rotate and protect it.	

03 ID token validation

Decode ≠ trust. Validate every item before creating a session.

Signature	Verify with a trusted key selected by kid and the expected algorithm. Decoding is not verification.
Issuer	iss exactly equals the configured or discovered issuer.
Audience	aud contains this client_id; validate azp when multiple audiences exist.
Expiry	exp is in the future; also check nbf/iat with a small clock-skew allowance.
Nonce	nonce equals the one stored for this browser transaction, then discard it.

State binds the authorization response to the browser transaction; **nonce** binds the ID token to that transaction. Both must be exact and single-use.

02 Authorization Code + PKCE flow

- 1 Create transaction**
Client creates state, nonce, and a PKCE verifier; stores them before redirecting.
- 2 Authorize**
Browser opens /authorize with client_id, exact redirect_uri, scope, state, nonce, and S256 challenge.
- 3 Sign in + consent**
Authorization server authenticates the person and records the grant.
- 4 Callback**
Browser returns one code and state to the registered client callback.
- 5 Redeem**
Client sends the code, redirect_uri, and PKCE verifier to the token endpoint once.
- 6 Validate + use**
Client validates the ID token; the resource API validates the access token it receives.

Redirect URI: register exact values and match exactly. Native exceptions use claimed HTTPS, private-use, or loopback redirects; only the loopback port may vary.

04 Troubleshooting order

SYMPTOM	TRACE	INVARIANT	NEXT CHECK
redirect_uri_mismatch	authorize + registration	Exact; loopback port is the sole dynamic exception.	Compare scheme, host, port, path, query, encoding. Stop.
State mismatch	Callback + transaction	Exact, same transaction, one-use.	Discard it; restart fresh.
Nonce mismatch	ID token + transaction	Exact, same transaction, one-use.	Reject session; inspect iss/aud.
Lost login / cookie	Callback cookie + proxy	Callback resumes same server session.	Check SameSite, Secure, domain, path, proxy.
Issuer / audience	Discovery + ID token claims	iss exact; aud/azp valid for client_id.	Check metadata, JWKS, client config.

Stop at the first broken invariant. Fix it, restart with a fresh transaction, then continue down the list.